

KERALA AYURVEDIC LIFESTYLE

Complete Project Report

A TO Z — WHAT WE BUILT, WHY IT'S SECURE & FAST

Public Website & Shop

Booking & Consultation

Admin & Staff Portals

Security & Performance

Prepared by **Aurexis Solution**

For: Kerala Ayurvedic Lifestyle — Brickfields, Kuala Lumpur

keralaayurvediclifestyle.com.my

Report v1 · Full Delivery Summary

This report is a full **A–Z account of everything built** for Kerala Ayurvedic Lifestyle — the public website and online shop, the native booking & consultation system, the customer account area, and the complete back-office (front desk, doctor, admin and sales-partner portals). It also explains, in plain language, **why the platform is secure, why it is fast, what is currently "archived"** (built but switched off until the next phase), and how the delivered work maps **against the Phase 2 proposal**.

Contents

- | | |
|----------------------------------|--------------------------------------|
| 1. At a glance | 8. Sales partner / agent portal |
| 2. Technology & integrations | 9. Accounts, login & roles |
| 3. Public website & shop | 10. Payments & email |
| 4. Booking & consultation system | 11. Phase 2 — proposal vs. delivered |
| 5. Customer account area | 12. Why it is secure |
| 6. Front desk & doctor portals | 13. Why it is fast |
| 7. Admin back-office | 14. What is "archived" |
| | 15. Status & recommended next steps |

1. At a glance

A single, integrated platform runs the clinic and its online business — one login system, one database, one admin. Everything below is **built and deployed live** on Vercel.

5

USER ROLES

4

STAFF / PARTNER
PORTALS

15+

ADMIN MODULES

10+

ACCOUNT
FEATURES

100%

MOBILE
RESPONSIVE

- **Public website** — brand pages, treatments catalogue (with photos), an online product shop, blog and contact.
- **Online booking & consultation** — customers request treatments or consultations, staff approve and assign a therapist, and customers pay online by FPX.
- **Customer accounts** — a personal dashboard for appointments, orders, health profile, the Prakriti body-type assessment, support messages, wishlist, reviews and vouchers.
- **Staff dashboards** — a Front Desk console, a Doctor portal, and a full Admin back-office.
- **Sales-partner portal** — for affiliates / resellers to track commissions, submit marketplace sales and buy wholesale stock.

2. Technology & integrations

LAYER	WHAT WE USE	USED FOR
Website framework	Next.js 14 (React, TypeScript)	The whole site — fast, modern, SEO-friendly
Database & accounts	Supabase (PostgreSQL)	Customers, treatments, products, orders, appointments, reviews, vouchers, logins
Content (CMS)	Sanity.io	Blog posts, About-page content, FAQs
Payments	Billplz (FPX / online banking)	Treatment & product payments — Malaysian banking
Email	SMTP via Brevo	Booking & order confirmations, payment links, reminders
Hosting & automation	Vercel (edge + cron)	Live hosting, automatic deploys, scheduled slot-release job
Design	Tailwind CSS	The burgundy & gold branded look, fully responsive

The treatment catalogue and product shop both run on Supabase (one system, editable from the admin — no developer needed to change prices or details). Sanity handles long-form content (blog, about, FAQs).

3. Public website & shop

Homepage

- Branded hero, the clinic's story & heritage, featured therapies, testimonials and FAQs — fully responsive on phone, tablet and desktop.
- Built-in **SEO structured data** (LocalBusiness, FAQ, ratings) so Google can show the clinic richly in search.

Treatments catalogue

- Browse by category — Massage, Face Care, Hair & Scalp, Stress & Sleep, Joint Care, Panchakarma, Kids, Post-natal and more — each treatment has a photo, description, benefits, duration and price.
- Every treatment page has a **Book** button leading straight into the booking flow.
- Fully editable from the admin.

Online product shop

- Browse products, view detail pages, add to **cart**, and check out — paying by FPX / online banking via Billplz.
- Live **stock tracking** so out-of-stock items are handled correctly.

Other pages

- **Blog** (articles), **About** (heritage & practitioner), **Contact** (form + FAQs), and a **Partners** landing page for affiliates / resellers.

4. Booking & consultation system

A native booking engine (no third-party calendar), with two journeys:

Direct treatment: pick treatment → choose date & slot → submit request → staff approve & assign therapist → **pay online** → confirmed

Consultation-first: request consultation → pick time → approve → consultation (free) → doctor clears guest → book & pay for treatment → confirmed

- Book as a **guest** or signed in. A "Before you book" arrival note and policy disclaimers (same-gender therapist, non-refundable cancellation window, WhatsApp rescheduling) are shown at checkout.
- **Smart time-slot picker** — dates from tomorrow onward, 30-minute slots, last slot adjusted to therapy length, with a 30-minute buffer after each booking. Only times where a same-gender therapist is genuinely free appear, so the clinic is **never double-booked** — and the therapist's name is never shown to the customer.
- **Group bookings** — a couple or up to 6 guests in one request, each with name, gender and age; the group pays once, after all guests are approved.
- **Payment window & auto-release** — an approved booking must be paid within 15 hours; a reminder email is sent, and if the window lapses the slot is automatically released and re-opened.
- Every request appears on the front-desk, doctor and admin dashboards; any one can approve, or reject with a reason so the guest can easily re-book.

5. Customer account area for signed-in customers

SECTION	WHAT THE CUSTOMER CAN DO
Dashboard	Personalised overview — next appointment, recent orders, unread messages, quick actions
Appointments	View upcoming / past appointments, download to their calendar (.ics), see aftercare notes
Orders	Order history by status, live shipment tracking, download invoices (paid orders)
Assessments	Take the Prakriti body-type quiz & see results + product recommendations; deeper assessments unlock after a Vaidya review
Profile	Update details, avatar, health intake (allergies, medications, conditions), communication preferences, password & security
Messages	Open support tickets and chat with the clinic; WhatsApp quick-contact
Addresses	Save multiple delivery addresses, set a default
Wishlist	Save products to buy later
Reviews	See submitted product reviews and their moderation status
Promos & wallet	View & claim vouchers, see balances and expiry, redemption history

6. Front desk & doctor portals

Front Desk — Bookings Console /console

- **Today** board (one-tap check-in / start / complete + WhatsApp / call), **New requests**, **Awaiting payment**, **Confirmed**, a live **Therapists** availability board, **All**, instant **Search**, and + **New booking** for walk-ins.
- **Visual day schedule** — therapists across the top, time down the side, appointments as colour-coded blocks, per-day counts, a waiting-list column, and clear "day off" markers.
- Approve a request → select the guest's preferred or alternate time → assign a same-gender therapist → guest pays. Reject with a reason, or delete as needed.
- **Availability controls** — block a slot for one therapist or the whole centre, repeat it weekly / monthly, and mark staff on leave; blocked / on-leave therapists drop out of booking and assignment automatically.

Doctor — Doctor Portal /doctor

- **Overview**, **Schedule**, **Requests**, **Calendar** (by day), **Patients** directory (with health history), and **Consultations** to clear.
- For each booked guest the doctor sees name, prior health information and contact number, can add clinical notes, and can clear a consultation for treatment.

7. Admin back-office /admin

A complete operations centre — each module below is fully working:

MODULE	WHAT IT DOES
Dashboard	Live KPIs — revenue, pending payments, stock health, today's consultations, trends, attention queue
Appointments	List / filter / search bookings, create walk-ins, open the approve & assign screen
Treatments	Manage the treatment catalogue, categories, pricing, durations and photos
Products	Create / edit products, bulk CSV import / export, pricing & categories
Inventory	Stock levels, manual adjustments, low-stock alerts, stock-movement ledger
Customers	Search, profiles & history, tags / segments, birthdays view, push vouchers
Orders	Manage orders by status, mark paid, print invoice / label / packing slip, batch print
Marketplace orders	Shopee / Lazada / TikTok order channel with approval workflow
Wholesale orders	Reseller bulk orders at wholesale pricing
Partners	Affiliate directory, commissions, leaderboard, payouts, external sales
Promos	Create vouchers (% / fixed / free shipping), public or private, expiry & usage
Finance	Revenue, refunds, AOV, commission summary, sales by channel
Reviews	Moderate product reviews (approve / reject)
Messages	Customer support ticket queue with status workflow
Audit log	Read-only record of who did what and when (compliance)
Settings	Clinic-wide configuration (details, tax, shipping, booking rules)

8. Sales partner / agent portal /agent

- **Referral dashboard** — a unique referral code & QR, monthly & lifetime sales, commissions earned.
- **Marketplace submissions** — log sales from Shopee / TikTok / Lazada / Instagram / WhatsApp for admin approval.
- **Wholesale shop** — buy stock at partner pricing to resell.
- **Commissions & payouts** tracking, and a profile with payout / bank details.

9. Accounts, login & roles

- **Customers** sign up / log in with email & password (optional "Continue with Google"). A 6-digit email verification (OTP) can be switched on or off.
- **Five roles**, each routed to its own area and protected so no one sees another's pages: Customer (account), Front Desk (console), Doctor (doctor portal), Admin (back-office), Sales Agent (partner portal).
- Affiliate **referral links** (?ref=CODE) are tracked for commission attribution.

10. Payments & email

- **Payments — Billplz (FPX / online banking)**. Treatments are paid in full online after approval; products are paid at checkout. Payment auto-confirms the booking / order. Refunds are processed from the Billplz dashboard. Consultations are free.
- **Email — Brevo (SMTP)**. Sends booking & order confirmations, payment links, reminders and rejection / auto-release notices. The system is provider-agnostic, so the email provider can be swapped without code changes.

11. Phase 2 — proposal vs. delivered

Every item from the approved Phase 2 proposal is **built and live**. This table traces each scope item to its delivery.

REF	PROPOSAL ITEM	STATUS
P2.0	Booking-page content — "Before you book" 15-min arrival note; female "on my period / not on my period" question	DELIVERED
P2.1	Smart customer time-slot picker — date from tomorrow, 30-min slots, length-aware last slot, 30-min buffer, same-gender availability, therapist name hidden	DELIVERED
P2.2	Availability controls — block slots (one-off or weekly / monthly repeat); staff leave & off-day locking; auto-removal from availability	DELIVERED
P2.3	Visual staff schedule — day grid, therapists as columns, coloured blocks, per-day counts, waiting-list column, day-off markers	DELIVERED
P2.4	Payment-link 15-hour expiry & auto-release, with reminder email; slot re-opens on lapse	DELIVERED
P2.5	Approval refinements — "Guest" wording; read-only Preferred / Alternate times to select from; reject-with-reason and re-book	DELIVERED
P2.6	Group / multi-guest bookings — 2–6 guests, each with name, gender, age; one combined payment; grouped on the schedule	DELIVERED

CONFIRMED SETTING	VALUE DELIVERED
Open days	All 7 days
Customer booking window	9:30 AM first slot · last start 7:30 PM (1-hr) / 7:00 PM (90-min)
Centre hours (displayed)	9:00 AM – 9:00 PM
Therapist visibility	Hidden from customers — doctor / front desk assigns
Payment window	15 hours, then auto-released
Notifications	Email only

Built on the existing live platform with no migration — the current site kept running throughout, and each phase was reviewed and approved as it was delivered.

12. Why it is secure

Security is layered — a request has to pass several independent checks before it can read or change anything. These are the protections actually built into the platform:

Managed, industry-standard sign-in

Accounts and sessions are handled by **Supabase Auth** — a managed service used by thousands of companies — over secure, server-side session cookies. Passwords are never stored by us in readable form. Sign-in supports email & password, one-time email codes (OTP), and "Continue with Google". Signups are validated (email format, minimum 8-character password) before an account is created.

Two layers of role protection

Every staff and customer area is gated **twice**: first at the front door (middleware checks your role on every request and redirects you to your own portal), and again on the server before any sensitive action runs. An Admin URL simply cannot be opened by a customer, doctor or agent — the five roles (customer, front desk, doctor, admin, sales agent) are kept strictly apart.

Database-level Row-Level Security (RLS)

Even if application code were bypassed, the database itself enforces the rules. Postgres **RLS policies** ensure a customer can only ever read their *own* appointments, orders and messages, an agent can only see *their* marketplace orders (and can't approve their own), and only admins can change protected records. Full-access "service-role" keys are used **only on the server, after the role is verified** — never in the browser.

Cryptographically verified payments

Payment confirmations from Billplz are verified with an **HMAC-SHA256 X-Signature** using a secret only the server knows, compared in a **timing-safe** way (resistant to timing attacks). A booking is marked paid **only** after this check passes. The amount is always computed **on the server from the database** — never trusted from the browser — so prices can't be tampered with. Confirmation is idempotent (a replayed callback can't double-charge or double-confirm). Incoming Cal.com webhooks are verified the same way.

Protected links, secrets & audit trail

Guest booking links are protected by a **private signed token** (and the system refuses to run in production without its signing secret set). All secret keys (service role, Billplz, email) live only in server environment variables and are kept out of the code repository via `.gitignore`. Sensitive staff actions and every order status change are written to an **audit log** (who did what, when) for accountability, and customer health data is treated as **PDPA-protected**.

Recommended hardening before public launch: turn customer email-OTP back on, add explicit security response headers (CSP / HSTS) at the hosting layer, and verify the clinic domain in Brevo for best email delivery — see Section 15.

13. Why it is fast

Speed is designed in, not bolted on. The site is built on modern rendering techniques that send the browser the least work possible:

TECHNIQUE	WHAT IT MEANS FOR SPEED
Next.js 14 server components	Pages are rendered on the server and sent as ready-made HTML, so very little JavaScript ships to the phone — pages appear quickly even on mobile data.
Cached & pre-built pages (ISR)	Home, About, Contact and Blog are served from a cache and quietly refreshed, so most visitors get an near-instant page. Every treatment and blog page is pre-generated.
Global image CDN + optimisation	Photos are delivered from Sanity's and Supabase's global CDNs in modern formats and correct sizes, so images load fast without slowing the page.
Vercel edge hosting	The site is served from Vercel's global edge network with automatic deployments — close to the user, always on.
Optimised fonts	Fonts load with a "swap" strategy and are automatically subset, so text is readable immediately with no invisible-text flash.
Efficient database queries	Admin lists use pagination and indexed columns, so large tables (orders, customers, appointments) stay quick to load and filter.
Lean styling & code-splitting	Tailwind ships only the CSS actually used, and each page loads only the code it needs; animations run on the client without blocking content.
Automatic background jobs	Housekeeping such as releasing unpaid slots runs on a scheduled server cron — never on the visitor's device.

The result: fast first paint, strong mobile performance, and search-engine-friendly pages (server-rendered HTML with structured data).

14. What is "archived"

"Archived" means **fully built but intentionally switched off** for the current clinic-first (bookings-only) launch. Nothing is deleted — it can be turned on later without rebuilding. There are three kinds of "archive" in the project:

a) Phase-2 commerce, hidden behind one switch

The full online shop and partner programme are complete but hidden by a single feature flag (`COMMERCE_ENABLED`). While it's off, the clinic runs on bookings only, and these are removed from the menus and dashboards — yet remain ready to go live instantly:

Customer-facing (archived):

- Product shop & product pages
- Home-page shop & promo sections
- Account: Orders, Wishlist, Promo wallet, Reviews, Addresses
- "Brand Partner" navigation link

Admin-facing (archived):

- Products, Inventory, Orders
- Marketplace & Wholesale orders
- Brand Partners & Agent submissions
- Vouchers & Finance; shop KPIs on the dashboard

These routes still exist and work — they are simply not shown in the sidebars until commerce is switched on.

b) "Archived" product status (soft-delete)

Within the product catalogue, each product can be **Active**, **Draft** or **Archived**. Archiving a product hides it from the shop without deleting it or losing its history — a safe way to retire an item and bring it back later.

c) Design & planning archive (internal)

Early prototypes, mockup variants (business-card, hero and directory explorations) and the original planning documents are kept in the project's `/mockups`, `/prototypes` and `docs` folders for reference — not part of the live site, but retained so the design history isn't lost.

15. Status & recommended next steps

LIVE Website, shop engine, booking & consultation, all dashboards, payments (Billplz), email (Brevo), Phase 2 upgrades, treatment photos — all built and deployed.

ARCHIVED / READY Full commerce & partner programme — built, switched off, one flag away from launch.

BEFORE PUBLIC LAUNCH Recommended final touches:

- Turn customer email-OTP verification back **on** (it can be off for testing).
- Verify the clinic **domain in Brevo** for best email inbox delivery.
- Add explicit **security response headers** (CSP / HSTS) at the hosting layer for defence-in-depth.
- Optional: enable automated appointment **reminders**, and flip on **commerce** when the shop is ready.